

Análisis de Reconocimiento & Vulnerabilidades

TARGET: vulnerable-website.com

Tipo de análisis

Fecha de análisis

Autor del informe

Clasificación

5	10	28	10	14
CRITICAL	HIGH	MEDIUM	LOW	INFO

1. Resumen Ejecutivo

El análisis de seguridad realizado sobre el objetivo **vulnerable-website.com** con metodología **BLACKBOX** ha identificado un total de **67 hallazgos de seguridad**, de los cuales **15** son de severidad alta o crítica. El nivel de riesgo global estimado es **CRÍTICO**.

El análisis fue realizado el **11/06/2026 a las 19:23:34** y tuvo una duración de **28 segundos**.

Distribución de hallazgos por severidad:

Severidad	Cantidad	Impacto	Acción recomendada
CRITICAL	5	Compromiso total del sistema	Remediar de inmediato (< 24h)
HIGH	10	Compromiso parcial o escalación	Remediar urgentemente (< 7 días)
MEDIUM	28	Exposición de datos o degradación	Planificar corrección (< 30 días)
LOW	10	Riesgo limitado o teórico	Corregir en próximo ciclo
INFO	14	Sin impacto directo	Revisar y documentar

2. Alcance y Metodología

2.1 Definición del alcance

Target	vulnerable-website.com
Tipo	DOMAIN
IPs resueltas	34.249.203.140, 34.246.169.176
Modalidad	BLACKBOX
Fecha inicio	2026-06-11 19:23:34
Fecha fin	2026-06-11 19:24:02
Duración	0:00:28.525045

2.2 Metodología

El análisis se ha realizado siguiendo un enfoque estructurado por fases, partiendo de reconocimiento pasivo (OSINT) hasta análisis activo de protocolos y búsqueda de vulnerabilidades. Las fases ejecutadas son:

Fase 1 — OSINT	WHOIS, DNS, AXFR, certificados (crt.sh), ASN/BGP
Fase 2 — Shodan	Servicios expuestos, puertos, banners, CVEs indexados
Fase 3 — Leak-Lookup	Credenciales y emails filtrados en brechas conocidas
Fase 4 — Enumeración	Subdominios, hosts activos, detección de tecnologías
Fase 5 — SSL/TLS	Protocolos, cifrados, certificado, HSTS, vulnerabilidades
Fase 6 — Cabeceras HTTP	Security headers, CSP, cookies, fugas de información
Fase 7 — CVEs	Búsqueda en NVD/NIST por productos y versiones detectadas

3. Hallazgos de Seguridad

CRITICAL — 5 hallazgo(s)

[CVEs] CVE: CVE-1999-0454

Descripción: A remote attacker can sometimes identify the operating system of a host based on how it reacts to some IP or ICMP packets, using a tool such as nmap or queso.

CVSS Score: 10.0

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2007-1724

Descripción: Unspecified vulnerability in ReactOS 0.3.1 has unknown impact and attack vectors, related to a fix for "dozens of win32k bugs and failures," in which the fix itself introduces a vulnerability, possibly related to user-mode and kernel-mode copy failures.

CVSS Score: 10.0

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2018-6342

Descripción: react-dev-utils on Windows allows developers to run a local webserver for accepting various commands, including a command to launch an editor. The input to that command was not properly sanitized, allowing an attacker who can make a network request to the server (either via CSRF or by direct request) to execute arbitrary commands on the targeted system. This issue affects multiple branches: 1.x.x prior to 1.0.4, 2.x.x prior to 2.0.2, 3.x.x prior to 3.1.2, 4.x.x prior to 4.2.2, and 5.x.x prior to

CVSS Score: 9.8

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2019-12164

Descripción: ubuntu-server.js in Status React Native Desktop before v0.57.8_mobile_ui allows Remote Code Execution.

CVSS Score: 9.8

Mitigación: Aplicar parche del fabricante:
<https://github.com/status-im/react-native-desktop/compare/e77167f...7477eef>

[CVEs] CVE: CVE-2010-2446

Descripción: Rbot Reaction plugin allows command execution

CVSS Score: 9.8

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

HIGH — 10 hallazgo(s)

[CVEs] CVE: CVE-2019-11284

Descripción: Pivotal Reactor Netty, versions prior to 0.8.11, passes headers through redirects, including authorization ones. A remote unauthenticated malicious user may gain access to credentials for a different server than they have access to.

CVSS Score: 8.6

Mitigación: Aplicar parche del fabricante: <https://pivotal.io/security/cve-2019-11284>

[CVEs] CVE: CVE-2016-10697

Descripción: react-native-baidu-voice-synthesizer is a baidu voice speech synthesizer for react native. react-native-baidu-voice-synthesizer downloads resources over HTTP, which leaves it vulnerable to MITM attacks. It may be possible to cause remote code execution (RCE) by swapping out the requested resources with an attacker controlled copy if the attacker is on the network or positioned in between the user and the remote server.

CVSS Score: 8.1

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2007-0404

Descripción: bin/compile-messages.py in Django 0.95 does not quote argument strings before invoking the msgfmt program through the os.system function, which allows attackers to execute arbitrary commands via shell metacharacters in a (1) .po or (2) .mo file.

CVSS Score: 7.5

Mitigación: Aplicar parche del fabricante: <http://secunia.com/advisories/23826>

[CVEs] CVE: CVE-2011-0698

Descripción: Directory traversal vulnerability in Django 1.1.x before 1.1.4 and 1.2.x before 1.2.5 on Windows might allow remote attackers to read or execute files via a / (slash) character in a key in a session cookie, related to session replays.

CVSS Score: 7.5

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/02/09/6>

[CVEs] CVE: CVE-2002-0956

Descripción: BlackICE Agent 3.1.eal does not always reactivate after a system standby, which could allow remote attackers and local users to bypass intended firewall restrictions.

CVSS Score: 7.5

Mitigación: Aplicar parche del fabricante: http://www.iss.net/security_center/static/9275.php

[CVEs] CVE: CVE-2006-4073

Descripción: Multiple PHP remote file inclusion vulnerabilities in Fabian Hainz phpCC Beta 4.2 allow remote attackers to execute arbitrary PHP code via a URL in the base_dir parameter to (1) login.php, (2) reactivate.php, or (3) register.php.

CVSS Score: 7.5

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2007-4244

Descripción: PHP remote file inclusion vulnerability in langset.php in J! Reactions (com_jreactions) 1.8.1 and earlier, a Joomla! component, allows remote attackers to execute arbitrary PHP code via a URL in the comPath parameter.

CVSS Score: 7.5

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2017-7920

Descripción: An Improper Authentication issue was discovered in ABB VSN300 WiFi Logger Card versions 1.8.15 and prior, and VSN300 WiFi Logger Card for React versions 2.1.3 and prior. By accessing a specific uniform resource locator (URL) on the web server, a malicious user is able to access internal information about status and connected devices without authenticating.

CVSS Score: 7.5

Mitigación: Aplicar parche del fabricante: <http://search.abb.com/library/Download.aspx?DocumentID=9AKK107045A1977&LanguageCode;=en&DocumentPartId;=&Action;=Launch>

[CVEs] CVE: CVE-2018-7838

Descripción: A CWE-119 Buffer Errors vulnerability exists in Modicon M580 CPU - BMEP582040, all versions before V2.90, and Modicon Ethernet Module BMENOC0301, all versions before V2.16, which could cause denial of service on the FTP service of the controller or the Ethernet BMENOC module when it receives a FTP CWD command with a data length greater than 1020 bytes. A power cycle is then needed to reactivate the FTP service.

CVSS Score: 7.5

Mitigación: Aplicar parche del fabricante:
<https://www.schneider-electric.com/ww/en/download/document/SEVD-2019-190-03>

[CVEs] CVE: CVE-2019-14261

Descripción: An issue was discovered on ABUS Secvest FUAA50000 3.01.01 devices. Due to an insufficient implementation of jamming detection, an attacker is able to suppress correctly received RF messages sent between wireless peripheral components, e.g., wireless detectors or remote controls, and the ABUS Secvest alarm central. An attacker is able to perform a "reactive jamming" attack. The reactive jamming simply detects the start of a RF message sent by a component of the ABUS Secvest wireless alarm system,

CVSS Score: 7.5

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

MEDIUM — 28 hallazgo(s)

[OSINT] SPF no configurado

Descripción: No se encontró registro SPF en los TXT del dominio. Permite spoofing de email.

CVSS Score: 5.3

Mitigación: Añadir registro TXT SPF: `v=spf1 include:... -all`

[OSINT] DMARC no configurado

Descripción: No se encontró registro _dmarc. Sin política DMARC el dominio es vulnerable a email spoofing.

CVSS Score: 5.3

Mitigación: Añadir registro TXT en _dmarc.: v=DMARC1; p=reject; rua=mailto:...

[SSL/TLS] HSTS no configurado

Descripción: El servidor no envía la cabecera Strict-Transport-Security. Permite ataques de downgrade.

CVSS Score: 6.5

Mitigación: Añadir: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

[Cabeceras HTTP] Cabecera de seguridad ausente: content-security-policy

Descripción: La cabecera content-security-policy no está presente en la respuesta HTTP.

CVSS Score: 6.1

Mitigación: Implementar una CSP restrictiva. Ejemplo mínimo: default-src 'self'

[Cabeceras HTTP] Cookie sin flag Secure: AWSALB

Descripción: La cookie 'AWSALB' no tiene el atributo Secure. Puede transmitirse en claro.

CVSS Score: 5.9

Mitigación: Añadir el atributo Secure a la cookie AWSALB.

[CVEs] CVE: CVE-2007-5828

Descripción: Cross-site request forgery (CSRF) vulnerability in the admin panel in Django 0.96 allows remote attackers to change passwords of arbitrary users via a request to admin/auth/user/1/password/. NOTE: this issue has been disputed by Debian, since product documentation includes a recommendation for a CSRF protection module that is included with the product. However, CVE considers this an issue because the default configuration does not use this module

CVSS Score: 6.8

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2011-0696

Descripción: Django 1.1.x before 1.1.4 and 1.2.x before 1.2.5 does not properly validate HTTP requests that contain an X-Requested-With header, which makes it easier for remote attackers to conduct cross-site request forgery (CSRF) attacks via forged AJAX requests that leverage a "combination of browser plugins and redirects," a related issue to CVE-2011-0447.

CVSS Score: 6.8

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/02/09/6>

[CVEs] CVE: CVE-2011-4140

Descripción: The CSRF protection mechanism in Django through 1.2.7 and 1.3.x through 1.3.1 does not properly handle web-server configurations supporting arbitrary HTTP Host headers, which allows remote attackers to trigger unauthenticated forged requests via vectors involving a DNS CNAME record and a web page containing JavaScript code.

CVSS Score: 6.8

Mitigación: *Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/09/11/1>*

[CVEs] CVE: CVE-2007-0405

Descripción: The LazyUser class in the AuthenticationMiddleware for Django 0.95 does not properly cache the user name across requests, which allows remote authenticated users to gain the privileges of a different user.

CVSS Score: 6.5

Mitigación: *Aplicar parche del fabricante: <http://secunia.com/advisories/23826>*

[CVEs] CVE: CVE-2017-7916

Descripción: A Permissions, Privileges, and Access Controls issue was discovered in ABB VSN300 WiFi Logger Card versions 1.8.15 and prior, and VSN300 WiFi Logger Card for React versions 2.1.3 and prior. The web application does not properly restrict privileges of the Guest account. A malicious user may be able to gain access to configuration information that should be restricted.

CVSS Score: 6.5

Mitigación: *Aplicar parche del fabricante: <http://search.abb.com/library/Download.aspx?DocumentID=9AKK107045A1977&LanguageCode;=en&DocumentPartId;=&Action;=Launch>*

[CVEs] CVE: CVE-2018-7197

Descripción: An issue was discovered in Pluck through 4.7.4. A stored cross-site scripting (XSS) vulnerability allows remote unauthenticated users to inject arbitrary web script or HTML into admin/blog Reaction Comments via a crafted URL.

CVSS Score: 6.1

Mitigación: *Consultar el advisory oficial y aplicar el parche correspondiente.*

[CVEs] CVE: CVE-2018-6341

Descripción: React applications which rendered to HTML using the ReactDOMServer API were not escaping user-supplied attribute names at render-time. That lack of escaping could lead to a cross-site scripting vulnerability. This issue affected minor releases 16.0.x, 16.1.x, 16.2.x, 16.3.x, and 16.4.x. It was fixed in 16.0.1, 16.1.2, 16.2.1, 16.3.3, and 16.4.2.

CVSS Score: 6.1

Mitigación: *Aplicar parche del fabricante: <https://reactjs.org/blog/2018/08/01/react-v-16-4-2.html>*

[CVEs] CVE: CVE-2008-3909

Descripción: The administration application in Django 0.91, 0.95, and 0.96 stores unauthenticated HTTP POST requests and processes them after successful authentication occurs, which allows remote attackers to conduct cross-site request forgery (CSRF) attacks and delete or modify data via unspecified requests.

CVSS Score: 5.8

Mitigación: Aplicar parche del fabricante: <http://www.djangoproject.com/weblog/2008/sep/02/security/>

[CVEs] CVE: CVE-2011-4136

Descripción: django.contrib.sessions in Django before 1.2.7 and 1.3.x before 1.3.1, when session data is stored in the cache, uses the root namespace for both session identifiers and application-data keys, which allows remote attackers to modify a session by triggering use of a key that is equal to that session's identifier.

CVSS Score: 5.8

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/09/11/1>

[CVEs] CVE: CVE-2017-1000386

Descripción: Jenkins Active Choices plugin version 1.5.3 and earlier allowed users with Job/Configure permission to provide arbitrary HTML to be shown on the 'Build With Parameters' page through the 'Active Choices Reactive Reference Parameter' type. This could include, for example, arbitrary JavaScript. Active Choices now sanitizes the HTML inserted on the 'Build With Parameters' page if and only if the script is executed in a sandbox. As unsandboxed scripts are subject to administrator approval, it is up t

CVSS Score: 5.4

Mitigación: Aplicar parche del fabricante: <https://jenkins.io/security/advisory/2017-10-23/>

[CVEs] CVE: CVE-2017-16028

Descripción: react-native-meteor-oauth is a library for OAuth2 login to a Meteor server in React Native. The oauth Random Token is generated using a non-cryptographically strong RNG (Math.random()).

CVSS Score: 5.3

Mitigación: Aplicar parche del fabricante: <https://nodesecurity.io/advisories/157>

[CVEs] CVE: CVE-2009-2659

Descripción: The Admin media handler in core/servers/basehttp.py in Django 1.0 and 0.96 does not properly map URL requests to expected "static media files," which allows remote attackers to conduct directory traversal attacks and read arbitrary files via a crafted URL.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://www.djangoproject.com/weblog/2009/jul/28/security/>

[CVEs] CVE: CVE-2009-3695

Descripción: Algorithmic complexity vulnerability in the forms library in Django 1.0 before 1.0.4 and 1.1 before 1.1.1 allows remote attackers to cause a denial of service (CPU consumption) via a crafted (1) EmailField (email address) or (2) URLField (URL) that triggers a large amount of backtracking in a regular expression.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://secunia.com/advisories/36948>

[CVEs] CVE: CVE-2010-4535

Descripción: The password reset functionality in django.contrib.auth in Django before 1.1.3, 1.2.x before 1.2.4, and 1.3.x before 1.3 beta 1 does not validate the length of a string representing a base36 timestamp, which allows remote attackers to cause a denial of service (resource consumption) via a URL that specifies a large base36 integer.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://code.djangoproject.com/changeset/15032>

[CVEs] CVE: CVE-2011-4137

Descripción: The verify_exists functionality in the URLField implementation in Django before 1.2.7 and 1.3.x before 1.3.1 relies on Python libraries that attempt access to an arbitrary URL with no timeout, which allows remote attackers to cause a denial of service (resource consumption) via a URL associated with (1) a slow response, (2) a completed TCP connection with no application data sent, or (3) a large amount of application data, a related issue to CVE-2011-1521.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/09/11/1>

[CVEs] CVE: CVE-2011-4138

Descripción: The verify_exists functionality in the URLField implementation in Django before 1.2.7 and 1.3.x before 1.3.1 originally tests a URL's validity through a HEAD request, but then uses a GET request for the new target URL in the case of a redirect, which might allow remote attackers to trigger arbitrary GET requests with an unintended source IP address via a crafted Location header.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/09/11/1>

[CVEs] CVE: CVE-2011-4139

Descripción: Django before 1.2.7 and 1.3.x before 1.3.1 uses a request's HTTP Host header to construct a full URL in certain circumstances, which allows remote attackers to conduct cache poisoning attacks via a crafted request.

CVSS Score: 5.0

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/09/11/1>

[CVEs] CVE: CVE-2008-2302

Descripción: Cross-site scripting (XSS) vulnerability in the login form in the administration application in Django 0.91 before 0.91.2, 0.95 before 0.95.3, and 0.96 before 0.96.2 allows remote attackers to inject arbitrary web script or HTML via the URI of a certain previous request.

CVSS Score: 4.3

Mitigación: Aplicar parche del fabricante: <http://secunia.com/advisories/30250>

[CVEs] CVE: CVE-2010-3082

Descripción: Cross-site scripting (XSS) vulnerability in Django 1.2.x before 1.2.2 allows remote attackers to inject arbitrary web script or HTML via a csrfmiddlewaretoken (aka csrf_token) cookie.

CVSS Score: 4.3

Mitigación: Aplicar parche del fabricante:

<http://www.djangoproject.com/weblog/2010/sep/08/security-release/>

[CVEs] CVE: CVE-2011-0697

Descripción: Cross-site scripting (XSS) vulnerability in Django 1.1.x before 1.1.4 and 1.2.x before 1.2.5 might allow remote attackers to inject arbitrary web script or HTML via a filename associated with a file upload.

CVSS Score: 4.3

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/02/09/6>

[CVEs] CVE: CVE-2012-3442

Descripción: The (1) django.http.HttpResponseRedirect and (2) django.http.HttpResponsePermanentRedirect classes in Django before 1.3.2 and 1.4.x before 1.4.1 do not validate the scheme of a redirect target, which might allow remote attackers to conduct cross-site scripting (XSS) attacks via a data: URL.

CVSS Score: 4.3

Mitigación: Aplicar parche del fabricante:

<https://www.djangoproject.com/weblog/2012/jul/30/security-releases-issued/>

[CVEs] CVE: CVE-2007-4844

Descripción: X-Diesel Unreal Commander 0.92 build 565 and 573 does not properly react to an FTP server's behavior after sending a "CWD /" command, which allows remote FTP servers to cause a denial of service (infinite loop) by (1) repeatedly sending a 550 error response, or (2) sending a 550 error response and then disconnecting.

CVSS Score: 4.3

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

[CVEs] CVE: CVE-2010-4534

Descripción: The administrative interface in django.contrib.admin in Django before 1.1.3, 1.2.x before 1.2.4, and 1.3.x before 1.3 beta 1 does not properly restrict use of the query string to perform certain object filtering, which allows remote authenticated users to obtain sensitive information via a series of requests containing regular expressions, as demonstrated by a created_by__password__regex parameter.

CVSS Score: 4.0

Mitigación: Aplicar parche del fabricante: <http://code.djangoproject.com/changeset/15031>

LOW — 10 hallazgo(s)

[Cabeceras HTTP] Cabecera de seguridad ausente: x-content-type-options

Descripción: La cabecera x-content-type-options no está presente en la respuesta HTTP.

CVSS Score: 4.3

Mitigación: *Añadir: X-Content-Type-Options: nosniff*

[Cabeceras HTTP] Cabecera de seguridad ausente: referrer-policy

Descripción: La cabecera referrer-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Referrer-Policy: strict-origin-when-cross-origin*

[Cabeceras HTTP] Cabecera de seguridad ausente: permissions-policy

Descripción: La cabecera permissions-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Permissions-Policy: geolocation=(), microphone=(), camera=()*

[Cabeceras HTTP] Cabecera de seguridad ausente: x-xss-protection

Descripción: La cabecera x-xss-protection no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: X-XSS-Protection: 1; mode=block (legacy, pero útil en navegadores antiguos)*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-embedder-policy

Descripción: La cabecera cross-origin-embedder-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Embedder-Policy: require-corp*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-opener-policy

Descripción: La cabecera cross-origin-opener-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Opener-Policy: same-origin*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-resource-policy

Descripción: La cabecera cross-origin-resource-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Resource-Policy: same-origin*

[Cabeceras HTTP] Cookie sin atributo SameSite: AWSALB

Descripción: La cookie 'AWSALB' no tiene SameSite. Riesgo de CSRF.

CVSS Score: 4.3

Mitigación: *Añadir SameSite=Strict o SameSite=Lax a la cookie AWSALB.*

[CVEs] CVE: CVE-2019-7176

Descripción: An issue was discovered in GitLab Community and Enterprise Edition 8.x (starting in 8.9), 9.x, 10.x, and 11.x before 11.5.9, 11.6.x before 11.6.7, and 11.7.x before 11.7.2. It has Incorrect Access Control. Guest users are able to add reaction emojis on comments to which they have no visibility.

CVSS Score: 3.7

Mitigación: Aplicar parche del fabricante:

<https://about.gitlab.com/2019/01/31/security-release-gitlab-11-dot-7-dot-3-released/>

[CVEs] CVE: CVE-2007-5712

Descripción: The internationalization (i18n) framework in Django 0.91, 0.95, 0.95.1, and 0.96, and as used in other products such as PyLucid, when the USE_I18N option and the i18n component are enabled, allows remote attackers to cause a denial of service (memory consumption) via many HTTP requests with large Accept-Language headers.

CVSS Score: 2.6

Mitigación: Aplicar parche del fabricante: <http://secunia.com/advisories/27435>

INFO — 14 hallazgo(s)

[OSINT] Email expuesto en WHOIS

Descripción: Email a visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email b visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email u visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email s visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email e visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email @ visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email n visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email a visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email m visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email e visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email . visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email c visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email o visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

[OSINT] Email expuesto en WHOIS

Descripción: Email m visible en registros WHOIS públicos.

Mitigación: Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.

4. Análisis SSL/TLS

4.1 Certificado X.509

CN (Subject)	vulnerable-website.com
Emisor (CA)	Amazon RSA 2048 M01
Válido desde	2026-01-05
Válido hasta	2027-02-03
Días restantes	237
Algoritmo firma	sha256
Tamaño de clave	2048 bits
Autofirmado	No
SHA-256	db994c763d659005ed492c0e418eb279b2857c95490871b9...

4.3 HSTS (HTTP Strict Transport Security)

Habilitado	No
max-age	0 segundos
includeSubDomains	No
preload	No
Cabecera completa	N/A

5. Cabeceras HTTP de Seguridad

Cabecera	Estado	Valor / Nota
x-frame-options	✓ Presente	SAMEORIGIN
content-security-policy	✗ Ausente	—
x-content-type-options	✗ Ausente	—
referrer-policy	✗ Ausente	—
permissions-policy	✗ Ausente	—
x-xss-protection	✗ Ausente	—
cross-origin-embedder-policy	✗ Ausente	—
cross-origin-opener-policy	✗ Ausente	—
cross-origin-resource-policy	✗ Ausente	—

6. OSINT & Reconocimiento

6.1 WHOIS

Registrador	Name.com, Inc.
Organización	Redacted for Privacy
País	GB
Creación	2018-10-16 14:53:45
Expiración	2026-10-16 14:53:45
Name Servers	NS-1299.AWSDNS-34.ORG, NS-1602.AWSDNS-08.CO.UK, NS-225.AWSDNS-28.COM, NS-633.AWS
Emails WHOIS	a, b, u, s, e, @, n, a, m, e, ., c, o, m

6.2 Registros DNS

Tipo	Valor
A	34.246.169.176
	34.249.203.140
NS	ns-633.awsdns-15.net.
	ns-1299.awsdns-34.org.
	ns-1602.awsdns-08.co.uk.
	ns-225.awsdns-28.com.
TXT	"Probely=34ff178a-380a-4acd-86b2-2739584c4c0c"
SOA	ns-1602.awsdns-08.co.uk. awsdns-hostmaster.amazon.com. 1 7200 900 1209600 86400

6.3 Subdominios (2 encontrados)

FQDN	IPs
www.vulnerable-website.com	34.249.203.140, 34.246.169.176
vulnerable-website.com	34.249.203.140, 34.246.169.176

7. CVEs Identificados

Se han identificado 40 CVE(s) asociados a los productos y versiones detectados durante el análisis, consultados contra la base de datos NVD/NIST.

CVE ID	Producto	CVSS	Severidad	Publicado
CVE-1999-0454	React	10.0	CRITICAL	1999-01-01
CVE-2007-1724	React	10.0	CRITICAL	2007-03-28
CVE-2018-6342	React	9.8	CRITICAL	2018-12-31
CVE-2019-12164	React	9.8	CRITICAL	2019-07-23
CVE-2010-2446	React	9.8	CRITICAL	2019-11-06
CVE-2019-11284	React	8.6	HIGH	2019-10-17
CVE-2016-10697	React	8.1	HIGH	2018-06-04
CVE-2007-0404	Django	7.5	HIGH	2007-01-23
CVE-2011-0698	Django	7.5	HIGH	2011-02-14
CVE-2002-0956	React	7.5	HIGH	2002-10-04
CVE-2006-4073	React	7.5	HIGH	2006-08-11
CVE-2007-4244	React	7.5	HIGH	2007-08-08
CVE-2017-7920	React	7.5	HIGH	2017-08-07
CVE-2018-7838	React	7.5	HIGH	2019-07-15
CVE-2019-14261	React	7.5	HIGH	2019-09-03
CVE-2007-5828	Django	6.8	MEDIUM	2007-11-05
CVE-2011-0696	Django	6.8	MEDIUM	2011-02-14
CVE-2011-4140	Django	6.8	MEDIUM	2011-10-19
CVE-2007-0405	Django	6.5	MEDIUM	2007-01-23
CVE-2017-7916	React	6.5	MEDIUM	2017-08-07
CVE-2018-7197	React	6.1	MEDIUM	2018-02-18
CVE-2018-6341	React	6.1	MEDIUM	2018-12-31
CVE-2008-3909	Django	5.8	MEDIUM	2008-09-04
CVE-2011-4136	Django	5.8	MEDIUM	2011-10-19
CVE-2017-1000386	React	5.4	MEDIUM	2018-01-26
CVE-2017-16028	React	5.3	MEDIUM	2018-06-04
CVE-2009-2659	Django	5.0	MEDIUM	2009-08-04
CVE-2009-3695	Django	5.0	MEDIUM	2009-10-13

CVE-2010-4535	Django	5.0	MEDIUM	2011-01-10
CVE-2011-4137	Django	5.0	MEDIUM	2011-10-19
CVE-2011-4138	Django	5.0	MEDIUM	2011-10-19
CVE-2011-4139	Django	5.0	MEDIUM	2011-10-19
CVE-2008-2302	Django	4.3	MEDIUM	2008-05-23
CVE-2010-3082	Django	4.3	MEDIUM	2010-09-14
CVE-2011-0697	Django	4.3	MEDIUM	2011-02-14
CVE-2012-3442	Django	4.3	MEDIUM	2012-07-31
CVE-2007-4844	React	4.3	MEDIUM	2007-09-12
CVE-2010-4534	Django	4.0	MEDIUM	2011-01-10
CVE-2019-7176	React	3.7	LOW	2019-09-09
CVE-2007-5712	Django	2.6	LOW	2007-10-30

Detalle de CVEs Críticos/Altos:

CVE-1999-0454 — CVSS 10.0 (CRITICAL)

A remote attacker can sometimes identify the operating system of a host based on how it reacts to some IP or ICMP packets, using a tool such as nmap or queso.

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

CVE-2007-1724 — CVSS 10.0 (CRITICAL)

Unspecified vulnerability in ReactOS 0.3.1 has unknown impact and attack vectors, related to a fix for "dozens of win32k bugs and failures," in which the fix itself introduces a vulnerability, possibly related to user-mode and kernel-mode copy failures.

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

CVE-2018-6342 — CVSS 9.8 (CRITICAL)

react-dev-utils on Windows allows developers to run a local webserver for accepting various commands, including a command to launch an editor. The input to that command was not properly sanitized, allowing an attacker who can make a network request to the server (either via CSRF or by direct request) to execute arbitrary commands on the targeted system. This issue affects multiple branches: 1.x.x

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

CVE-2019-12164 — CVSS 9.8 (CRITICAL)

ubuntu-server.js in Status React Native Desktop before v0.57.8_mobile_ui allows Remote Code Execution.

Mitigación: Aplicar parche del fabricante:

<https://github.com/status-im/react-native-desktop/compare/e77167f...7477eef>

CVE-2010-2446 — CVSS 9.8 (CRITICAL)

Rbot Reaction plugin allows command execution

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

CVE-2019-11284 — CVSS 8.6 (HIGH)

Pivotal Reactor Netty, versions prior to 0.8.11, passes headers through redirects, including authorization ones. A remote unauthenticated malicious user may gain access to credentials for a different server than they have access to.

Mitigación: Aplicar parche del fabricante: <https://pivotal.io/security/cve-2019-11284>

CVE-2016-10697 — CVSS 8.1 (HIGH)

react-native-baidu-voice-synthesizer is a baidu voice speech synthesizer for react native. react-native-baidu-voice-synthesizer downloads resources over HTTP, which leaves it vulnerable to MITM attacks. It may be possible to cause remote code execution (RCE) by swapping out the requested resources with an attacker controlled copy if the attacker is on the network or positioned in between the user

Mitigación: Consultar el advisory oficial y aplicar el parche correspondiente.

CVE-2007-0404 — CVSS 7.5 (HIGH)

bin/compile-messages.py in Django 0.95 does not quote argument strings before invoking the msgfmt program through the os.system function, which allows attackers to execute arbitrary commands via shell metacharacters in a (1) .po or (2) .mo file.

Mitigación: Aplicar parche del fabricante: <http://secunia.com/advisories/23826>

CVE-2011-0698 — CVSS 7.5 (HIGH)

Directory traversal vulnerability in Django 1.1.x before 1.1.4 and 1.2.x before 1.2.5 on Windows might allow remote attackers to read or execute files via a / (slash) character in a key in a session cookie, related to session replays.

Mitigación: Aplicar parche del fabricante: <http://openwall.com/lists/oss-security/2011/02/09/6>

CVE-2002-0956 — CVSS 7.5 (HIGH)

BlackICE Agent 3.1.eal does not always reactivate after a system standby, which could allow remote attackers and local users to bypass intended firewall restrictions.

Mitigación: Aplicar parche del fabricante: http://www.iss.net/security_center/static/9275.php

8. Tabla CVSS Consolidada

La siguiente tabla consolida todos los hallazgos con una puntuación CVSS asignada, ordenados por severidad descendente.

#	Hallazgo	Fase	CVSS	Severidad
1	CVE: CVE-1999-0454	CVEs	10.0	CRITICAL
2	CVE: CVE-2007-1724	CVEs	10.0	CRITICAL
3	CVE: CVE-2018-6342	CVEs	9.8	CRITICAL
4	CVE: CVE-2019-12164	CVEs	9.8	CRITICAL
5	CVE: CVE-2010-2446	CVEs	9.8	CRITICAL
6	CVE: CVE-2019-11284	CVEs	8.6	HIGH
7	CVE: CVE-2016-10697	CVEs	8.1	HIGH
8	CVE: CVE-2007-0404	CVEs	7.5	HIGH
9	CVE: CVE-2011-0698	CVEs	7.5	HIGH
10	CVE: CVE-2002-0956	CVEs	7.5	HIGH
11	CVE: CVE-2006-4073	CVEs	7.5	HIGH
12	CVE: CVE-2007-4244	CVEs	7.5	HIGH
13	CVE: CVE-2017-7920	CVEs	7.5	HIGH
14	CVE: CVE-2018-7838	CVEs	7.5	HIGH
15	CVE: CVE-2019-14261	CVEs	7.5	HIGH
16	CVE: CVE-2007-5828	CVEs	6.8	MEDIUM
17	CVE: CVE-2011-0696	CVEs	6.8	MEDIUM
18	CVE: CVE-2011-4140	CVEs	6.8	MEDIUM
19	HSTS no configurado	SSL/TLS	6.5	MEDIUM
20	CVE: CVE-2007-0405	CVEs	6.5	MEDIUM
21	CVE: CVE-2017-7916	CVEs	6.5	MEDIUM
22	Cabecera de seguridad ausente: content-security-policy	Cabeceras HTTP	6.1	MEDIUM
23	CVE: CVE-2018-7197	CVEs	6.1	MEDIUM
24	CVE: CVE-2018-6341	CVEs	6.1	MEDIUM
25	Cookie sin flag Secure: AWSALB	Cabeceras HTTP	5.9	MEDIUM
26	CVE: CVE-2008-3909	CVEs	5.8	MEDIUM
27	CVE: CVE-2011-4136	CVEs	5.8	MEDIUM
28	CVE: CVE-2017-1000386	CVEs	5.4	MEDIUM

29	SPF no configurado	OSINT	5.3	MEDIUM
30	DMARC no configurado	OSINT	5.3	MEDIUM
31	CVE: CVE-2017-16028	CVEs	5.3	MEDIUM
32	CVE: CVE-2009-2659	CVEs	5.0	MEDIUM
33	CVE: CVE-2009-3695	CVEs	5.0	MEDIUM
34	CVE: CVE-2010-4535	CVEs	5.0	MEDIUM
35	CVE: CVE-2011-4137	CVEs	5.0	MEDIUM
36	CVE: CVE-2011-4138	CVEs	5.0	MEDIUM
37	CVE: CVE-2011-4139	CVEs	5.0	MEDIUM
38	Cabecera de seguridad ausente: x-content-type-options	Cabeceras HTTP	4.3	LOW
39	Cookie sin atributo SameSite: AWSALB	Cabeceras HTTP	4.3	LOW
40	CVE: CVE-2008-2302	CVEs	4.3	MEDIUM
41	CVE: CVE-2010-3082	CVEs	4.3	MEDIUM
42	CVE: CVE-2011-0697	CVEs	4.3	MEDIUM
43	CVE: CVE-2012-3442	CVEs	4.3	MEDIUM
44	CVE: CVE-2007-4844	CVEs	4.3	MEDIUM
45	CVE: CVE-2010-4534	CVEs	4.0	MEDIUM
46	CVE: CVE-2019-7176	CVEs	3.7	LOW
47	Cabecera de seguridad ausente: referrer-policy	Cabeceras HTTP	3.1	LOW
48	Cabecera de seguridad ausente: permissions-policy	Cabeceras HTTP	3.1	LOW
49	Cabecera de seguridad ausente: x-xss-protection	Cabeceras HTTP	3.1	LOW
50	Cabecera de seguridad ausente: cross-origin-embedder-policy	Cabeceras HTTP	3.1	LOW
51	Cabecera de seguridad ausente: cross-origin-opener-policy	Cabeceras HTTP	3.1	LOW
52	Cabecera de seguridad ausente: cross-origin-resource-policy	Cabeceras HTTP	3.1	LOW
53	CVE: CVE-2007-5712	CVEs	2.6	LOW

9. Propuestas de Mitigación

A continuación se detallan las acciones de mitigación recomendadas, priorizadas por severidad e impacto potencial.

Prioridad	Hallazgo	Acción	Plazo
Inmediata	CVE: CVE-1999-0454	Consultar el advisory oficial y aplicar el parche correspondiente.	< 24 horas
Inmediata	CVE: CVE-2019-12164	Aplicar parche del fabricante: https://github.com/status-im/react-native-desktop/compare/e77167f...7477eef	< 24 horas
Urgente	CVE: CVE-2019-11284	Aplicar parche del fabricante: https://pivotal.io/security/cve-2019-11284	< 7 días
Urgente	CVE: CVE-2007-0404	Aplicar parche del fabricante: http://secunia.com/advisories/23826	< 7 días
Urgente	CVE: CVE-2011-0698	Aplicar parche del fabricante: http://openwall.com/lists/oss-security/2011/02/09/6	< 7 días
Urgente	CVE: CVE-2002-0956	Aplicar parche del fabricante: http://www.iss.net/security_center/static/9275.php	< 7 días
Urgente	CVE: CVE-2017-7920	Aplicar parche del fabricante: http://search.abb.com/library/Download.aspx?DocumentID=9AKK107045A1977&LanguageCode;=en&Do;	< 7 días
Urgente	CVE: CVE-2018-7838	Aplicar parche del fabricante: https://www.schneider-electric.com/ww/en/download/document/SEVD-2019-190-03	< 7 días
Planificada	SPF no configurado	Añadir registro TXT SPF: v=spf1 include:... -all	< 30 días
Planificada	DMARC no configurado	Añadir registro TXT en _dmarc.: v=DMARC1; p=reject; rua=mailto:...	< 30 días
Planificada	HSTS no configurado	Añadir: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload	< 30 días
Planificada	Cabecera de seguridad ausente: content-security-po	Implementar una CSP restrictiva. Ejemplo mínimo: default-src 'self'	< 30 días
Planificada	Cookie sin flag Secure: AWSALB	Añadir el atributo Secure a la cookie AWSALB.	< 30 días
Planificada	CVE: CVE-2011-4140	Aplicar parche del fabricante: http://openwall.com/lists/oss-security/2011/09/11/1	< 30 días
Planificada	CVE: CVE-2018-6341	Aplicar parche del fabricante: https://reactjs.org/blog/2018/08/01/react-v-16-4-2.html	< 30 días
Planificada	CVE: CVE-2008-3909	Aplicar parche del fabricante: http://www.djangoproject.com/weblog/2008/sep/02/security/	< 30 días
Planificada	CVE: CVE-2017-1000386	Aplicar parche del fabricante: https://jenkins.io/security/advisory/2017-10-23/	< 30 días
Planificada	CVE: CVE-2017-16028	Aplicar parche del fabricante: https://nodesecurity.io/advisories/157	< 30 días

Planificada	CVE: CVE-2009-2659	Aplicar parche del fabricante: http://www.djangoproject.com/weblog/2009/jul/28/security/	< 30 días
Planificada	CVE: CVE-2009-3695	Aplicar parche del fabricante: http://secunia.com/advisories/36948	< 30 días
Planificada	CVE: CVE-2010-4535	Aplicar parche del fabricante: http://code.djangoproject.com/changeset/15032	< 30 días
Planificada	CVE: CVE-2008-2302	Aplicar parche del fabricante: http://secunia.com/advisories/30250	< 30 días
Planificada	CVE: CVE-2010-3082	Aplicar parche del fabricante: http://www.djangoproject.com/weblog/2010/sep/08/security-release/	< 30 días
Planificada	CVE: CVE-2012-3442	Aplicar parche del fabricante: https://www.djangoproject.com/weblog/2012/jul/30/security-releases-issued/	< 30 días
Planificada	CVE: CVE-2010-4534	Aplicar parche del fabricante: http://code.djangoproject.com/changeset/15031	< 30 días
Normal	Cabecera de seguridad ausente: x-content-type-opti	Añadir: X-Content-Type-Options: nosniff	Próximo sprint
Normal	Cabecera de seguridad ausente: referrer-policy	Añadir: Referrer-Policy: strict-origin-when-cross-origin	Próximo sprint
Normal	Cabecera de seguridad ausente: permissions-policy	Añadir: Permissions-Policy: geolocation=(), microphone=(), camera=()	Próximo sprint
Normal	Cabecera de seguridad ausente: x-xss-protection	Añadir: X-XSS-Protection: 1; mode=block (legacy, pero útil en navegadores antiguos)	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-embedd	Añadir: Cross-Origin-Embedder-Policy: require-corp	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-opener	Añadir: Cross-Origin-Opener-Policy: same-origin	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-resour	Añadir: Cross-Origin-Resource-Policy: same-origin	Próximo sprint
Normal	Cookie sin atributo SameSite: AWSALB	Añadir SameSite=Strict o SameSite=Lax a la cookie AWSALB.	Próximo sprint
Normal	CVE: CVE-2019-7176	Aplicar parche del fabricante: https://about.gitlab.com/2019/01/31/security-release-gitlab-11-dot-7-dot-3-released/	Próximo sprint
Normal	CVE: CVE-2007-5712	Aplicar parche del fabricante: http://secunia.com/advisories/27435	Próximo sprint
Opcional	Email expuesto en WHOIS	Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.	Sin urgencia

Informe generado por recon-cli el 11/06/2026 a las 19:23:34. Este documento es confidencial y está destinado exclusivamente al equipo de seguridad autorizado.